

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 1 頁，共 13 頁

單選題 50 題（佔 100%）

C	1. 對於各式網路攻擊之防禦措施，以下敘述何者最正確？ (A) 入侵防禦系統（IPS）無法偵測網路攻擊，僅能進行阻擋 (B) 使用防火牆能有效阻擋分散式阻斷服務（DDoS）攻擊 (C) 透過佈署蜜罐（Honeypot）服務可偵測異常網路活動 (D) 入侵偵測系統（IDS）可偵測網路攻擊，並進行阻擋
B	2. 以下何者為通用型的弱點掃描工具（Vulnerability Scanner）？ (A) Nmap (B) OpenVAS (C) OWASP (D) SCAP
D	3. 請問在關於開放式系統互聯模型（Open System Interconnection Model, OSI）中，下列哪一層負責 IP 之間的傳輸？ (A) 應用層（Application Layer） (B) 表達層（Presentation Layer） (C) 傳輸層（Transport Layer） (D) 網路層（Network Layer）
C	4. 下列何種攻擊，無法透過主機實體（Physical）或邏輯（Logical）安全機制直接防禦？ (A) 暴力攻擊（Brute-Force Attack） (B) 阻斷服務攻擊（Denial-of-Service Attack） (C) 社交工程（Social Engineering） (D) 通訊埠掃描（Port Scan）
C	5. 下列何者「不」是阻斷式服務攻擊（Denial-of-Service Attack）？ (A) 持續發送惡意封包，導致主機當機 (B) 消耗系統全部的 CPU 運算能力 (C) 寄送有惡意連結的郵件給公司所有人員 (D) 向特定收件者發送成千上萬封電子郵件

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 2 頁，共 13 頁

C	6. 請問下列什麼方式，最適合來確認資料的完整性（Integrity）？ (A) 最低權限 (B) 設定記憶體의特定資料段「執行禁用位元（NX bit）」 (C) 數位簽章 (D) 使用 Base64 編碼
B	7. 下列何者是較安全的密碼設定？ (A) QAZWSXE (B) uZ@12230bbeffff (C) 1\$aZ5 (D) helloworld
C	8. 券商集體遭 DDoS（分散式阻斷服務）攻擊勒索信件，其中有多家券商的網站下單系統更實際遭受網路 DDoS 攻擊，造成交易量降低。該案例網站下單系統被攻擊，最直接影響是下列何種資訊安全特性？ (A) 機密性 (B) 完整性 (C) 可用性 (D) 不可否認性
A	9. 可以使用下列何者，降低廣播領域（Broadcast Domain）範圍？ (A) Virtual Local Area Network（VLAN） (B) Network Address Translate（NAT） (C) Dynamic Trunking Protocol（DTP） (D) Inter-Switch Link（ISL）
B	10. 以下關於 TCP 與 UDP 協定的特性，下列敘述何者較「不」正確？ (A) 兩者均屬於 OSI 模型中的傳輸層 (B) 兩者皆需進行三向式的握手程序 (C) TCP 速度較慢、UDP 速度較快 (D) TCP 穩定性高、UDP 穩定性低

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 3 頁，共 13 頁

C	11. 關於通訊安全的敘述，下列何者錯誤？ (A) 當兩個系統進行通訊時，務必確保系統透過安全通道進行通訊，獲授權存取雙方使用共用資源 (B) 安全通訊端層（SSL）是對網際網路通訊提供隱私、驗證和整合性的安全性通訊協定 (C) SSL 是通道加密，資料也加密保護 (D) 傳輸層安全標準（TLS）是標準網際網路通訊協定，可以加密處理電子郵件，確保郵件在傳輸過程中安全不外洩
A	12. 有關防火牆功能之敘述，下列何者錯誤？ (A) 過濾一般用戶所禁止的網路服務，許可之網路服務則無須過濾 (B) 具有內部使用者與外部網站伺服器不會建立雙方之 TCP/IP 連線，而是透過內部防火牆以網頁用戶端的身分向外部網站要求存取網頁資料的應用代理閘道防火牆（Application-Proxy Gateway Firewalls）功能 (C) 可以隱藏內部 IP 位址，讓外部無法得知內部網路實際 IP 的網路位址轉譯（NAT）模式 (D) 可以在不修改網路設備的設定下，提供動態封包過濾功能的透通橋接模式（Transparent Mode）
A	13. 企業外部網路可以包含組織的內部網路與外部夥伴組織之間的連結，夥伴可能是供應商或委外廠商等，為了讓互相信任的組織進行連線可以透過專線或架設虛擬私有網路來完成，其技術名稱為下列何項？ (A) VPN (B) LAN (C) DMZ (D) NAT
A	14. 基於安全性考量，管理員需要重檢視一部 Linux 系統的檔案權限，請問下列哪一個命令可以找出 Linux 系統中所有已被設定 SUID 的程式檔案？

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 4 頁，共 13 頁

	(A) find / -perm -4000 -type f (B) find / -perm -2000 -type f (C) find / -type +6000 -print (D) find / -type suid
A	15. 請問在 Linux 環境中十分著名的漏洞 (Dirty Cow, CVE 2016-5195)，以下針對這個漏洞的描述何者錯誤？ (A) 此漏洞是在 Linux PAM (Pluggable Authentication Modules for Linux) 機制上的異常，可以取得使用者的密碼 (B) 此漏洞主要是 Linux 核心記憶體處理子程序的異常所產生 (C) 利用此漏洞可以進行本地端服務提權 (D) 這個漏洞也會影響特定版本之 Android 手機
B	16. 下列何者「不」是微軟 Windows 作業系統中，具特權權限之帳號？ (A) Administrator (B) root (C) Administrators 群組中之一般使用者帳號 (D) Local System
D	17. 以下關於作業系統的安全敘述，何者較「不」正確？ (A) 作業系統可分配與管理系統資源、提供系統服務與保護 (B) Administrator 是微軟 Windows 作業系統中，具特權權限之帳號應妥善管理 (C) 定期自動更新、安裝並更新防毒軟體皆屬於作業系統安全預防 (Preventive) 機制 (D) 當作業系統安裝好之後，為了避免因為安全因素導致作業系統遭受駭客入侵，最好直接更新入侵偵測系統
D	18. 當某 Windows 電腦，想要開放遠端桌面服務供其他電腦連入時，而該服務採用預設設定，請問防火牆應該開放下列哪一個通訊埠 (Port) ？ (A) 53

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 5 頁，共 13 頁

	(B) 23 (C) 443 (D) 3389
C	19. 請問 Metasploit 是下列何種用途的工具或平台？ (A) SQL Injection 工具 (B) XSS 工具 (C) 滲透測試平台 (D) 原始碼掃描工具
C	20. 請問一般所謂的 Google Hacking 是指下列何項？ (A) 遭 Google 公司入侵 (B) Google 公司被入侵 (C) 指透過大型搜尋引擎，收集欲入侵（滲透）標的之資訊 (D) 指透過 Google，對欲入侵（滲透）之公司直接發動攻擊
D	21. 關於憑證填充攻擊（Credential Stuffing）的敘述，下列何者錯誤？ (A) 通常使用殭屍網路（Botnet）進行攻擊 (B) 會以自動化方式試圖登入網路服務 (C) 可使用雙因子認證（two-factor authentication） (D) 會直接造成網路服務中斷，影響可用性
B	22. 如附圖所示，下列何項組合是 XSS（Cross-Site Scripting）攻擊語法？ (1) <script>alert('abc');</script> (2) ' or 1=1-- (3) (A) (1)(2) (B) (1)(3) (C) (2)(3) (D) (1)(2)(3)
A	23. 下列何者「不」是資料隱碼攻擊（SQL Injection）類型？ (A) Frame-Base SQL injection (B) Error-Base SQL injection

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 6 頁，共 13 頁

	(C) Time-Base SQL injection (D) Union-Base SQL injection
C	24. 為確保應用程式中之資料安全，所需採取的安全措施，下列敘述何者錯誤？ (A) 演算法、協議與金鑰即時更新，並有適當金鑰管理机制 (B) 確保所有隱私資料於儲存時進行加密 (C) 總是使用雜湊函式來代替加密函式 (D) 不儲存不必要的隱私資料，或儘速清除
A	25. 關於應用程式日誌管理保存的敘述，下列何者最「不」適當？ (A) 日誌必須儲存於本機以避免資料外流 (B) 日誌格式須確保被能使用之日誌管理方案支援 (C) 日誌須定期分析與監控，以即時發現可疑活動 (D) 日誌須留存足夠資訊以有效識別，如：時間、來源/目的、動作..等
C	26. 關於軟體測試的敘述，下列何者錯誤？ (A) 整合測試可以由程式設計師或軟體品保工程師進行 (B) 基本路徑測試是根據程式設計的內部架構產生測試資料 (C) 黑箱測試用於測試程式的輸出資料與對應輸入資料之間的正確性，需考慮軟體內部的結構 (D) 功能測試指測試系統是否能符合預期的功能需求
B	27. 關於程式原碼檢測（Code review）的敘述，下列何者錯誤？ (A) 通過檢查軟體程式的源代碼，發現和解決其中存在的潛在問題和漏洞 (B) 無助於開發人員在軟體開發及時發現並修復問題，從而提高軟體的質量和可靠性 (C) 可以查找內存泄漏、緩衝區溢出、程式碼注入等問題 (D) 代碼審查一般會分為三類：正式的代碼審查、結對

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 7 頁，共 13 頁

	程式，以及輕量型的非正式代碼審查
B	28. 從 Microsoft 安全性開發週期（Secure Development Life, SDL）的觀點，縮小攻擊面向（Attack Surface Reduction），主要是下列何項階段的考量？ (A) 需求階段（Requirements） (B) 設計階段（Design） (C) 實作階段（Implementation） (D) 發佈階段（Release）
C	29. 請問 CVSS（The Common Vulnerability Scoring System）是指下列何項？ (A) 常見漏洞和風險編號 (B) 弱點種類 (C) 弱點計分系統 (D) 漏洞修補建議
C	30. 網際網路已成為日常生活不可或缺的一部分，但部分使用者對安全防護不足容易受到惡意程式的危害。下列哪一項「不」是惡意程式？ (A) 木馬程式 (B) 勒索軟體 (C) 中間人攻擊 (D) 蠕蟲
D	31. 請問 DNS 快取污染(DNS Cache Poisoning)是針對開放式系統互聯模型（OSI Model – Open System Interconnection Model）的哪一層的攻擊？ (A) Layer 2 資料連接層（Data-Link Layer） (B) Layer 3 網路層（Network Layer） (C) Layer 4 傳送層（Transport Layer） (D) Layer 7 應用層（Application Layer）
C	32. 關於病毒（Virus）與蠕蟲（Worm）之比較，下列何者較正確？

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 8 頁，共 13 頁

	(A) 蠕蟲通常不具破壞性，病毒則通常為惡意 (B) 蠕蟲的檔案，通常比病毒小，不易被偵測 (C) 蠕蟲會自行擴散，病毒常透過事件觸發 (D) 蠕蟲無法自行存在，但病毒可以
B	33. 關於「弱點掃描」的描述，下列何者最「不」正確？ (A) 此作業可能會觸發入侵偵測系統的警告 (B) 可部署 Web 應用程式防火牆，來避免弱點掃描的探測 (C) 是滲透測試（Penetration Test）常見的前置作業之一 (D) Ping 工具的使用，是弱點掃描常用前置作業之一
C	34. 關於資料安全的敘述，下列何者錯誤？ (A) 資料安全性用於保護資料免受未經授權的存取，並保有資料機密性、完整性和可用性的保護措施 (B) 資料安全涵蓋內部環境和雲端服務，以降低資料外洩風險，並協助達成法規遵循 (C) 歐盟 GDPR 規定，企業資料外洩可處罰該公司全球收益 50% (D) GDPR 正式制定新的隱私原則，例如問責制度與資料最小化要求
A	35. 針對資料庫內外威脅所提出保護措施，下列敘述何者正確？ (A) 定期對存取資料庫的應用程式，進行源碼檢測以及 Web 黑箱檢測，降低駭客入侵風險 (B) MS-SQL 資料庫其檔案格式一定是.bak 的副檔名 (C) 企業資訊系統 MS-SQL 資料庫，可以採用系統管理者帳號進行管理，不需要為個別資料庫獨立帳號密碼 (D) 身為多個 MS-SQL 資料庫管理者，可採用同一組密碼，便於管控使用
C	36. 關於電腦檔案備份的敘述，下列何者錯誤？ (A) 檔案備份首重擬定備份策略，以確實發揮資料還原

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 9 頁，共 13 頁

	效果 (B) 將資料依重要性程度加以區分，在訂定資料備份策略時，才能掌握真正需要備份的標的 (C) 完整備份：備份空間有限的狀況下，十分適合使用完整備份 (D) 備份位置主要可分為「本機備份」、「異機備份」及「異地備份」三種不同方式
A	37. 請問下列何種備份策略，所需的儲存空間最少？ (A) 全備份配合增量備份 (B) 全備份配合差異備份 (C) 複製 (D) 差異備份配合增量備份
A	38. 在「行政院及所屬機關資訊安全管理規範」的日常作業之安全管理中，下列關於「資料備份」的作業原則何者錯誤？ (A) 資料應另外存放在離機關近距離的作業場所，以利方便存取 (B) 重要資料的備份，以維持三代為原則 (C) 備份資料應有適當的實體及環境保護，應以原主要作業場所為標準 (D) 資料的保存時間需求，應由資料擁有者研提
C	39. 在調查使用動態主機設定協定（Dynamic Host Configuration Protocol, DHCP）分配 IP 地址的網路時，應在下列何處查看並確定哪種媒體存取控制位址（Media Access Control Address, MAC）在特定時間具有特定的 IP 位址？ (A) 在個人計算機的位址解析協定（Address Resolution Protocol, ARP）緩存上 (B) 在 Web 伺服器日誌文件中 (C) 在 DHCP 伺服器日誌文件中 (D) 沒有辦法確定具體的 IP 地址
B	40. 若某公司以 UDP port 514 的方式，遠端蒐集 Syslog 進行日

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 10 頁，共 13 頁

	誌留存，請問下列敘述何者最正確？ (A) 遠端蒐集之日誌，無法作為有效證據 (B) 網路流量大時，有可能遺失封包（資料） (C) Syslog 無須考量加密即可保護資料傳輸之安全 (D) 遠端蒐集之日誌，存放時不應加密，以免破壞資料的正確性
D	41. 資料庫類型很多，常見 MS-SQL 資料庫，就有其日誌記錄，下列針對 MS-SQL 資料庫日誌敘述何者錯誤？ (A) 錯誤記錄檔是位於 Program Files\Microsoft SQL Server\MSSQL. n \MSSQL\LOG\ERRORLOG 和 ERRORLOG (B) MS-SQL 資料庫仍需要定期 TRANSACT 清除日誌 (C) MS-SQL 交易記錄檔過大，透過 SQL Query 來清除其語法 DBCC SHRINKFILE ('資料庫名稱_log ', 0, TRUNCATEONLY) (D) MS-SQL 記錄檔無法變更位置，因此我們必須預留相關磁碟空間，以及定期清理
B	42. 下列何項為應用系統日誌管理的主要目的？ (A) 加速系統的運作 (B) 用於故障排除、合規性記錄、支援威脅檢測、安全性問題確認等目的 (C) 監控系統用戶的操作 (D) 監督系統運用的效能
C	43. 日誌的功能是幫助資訊安全維運人員進行系統除錯、稽核取證與行為歸責的重要依據。請問下列描述何者錯誤？ (A) 記錄的內容包括設備的作業系統、發生的日期與時間、資料流量、使用者身份資料等 (B) 不同的資安設備可能產生不同的日誌格式，增加即時追蹤的困難度 (C) 將日誌存放在公開的儲存空間，可以提高判讀的速

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 11 頁，共 13 頁

	度 (D) 透過系統設定，系統可以根據日誌得到的資訊向監控者傳送警報訊息。
D	44. 有一項雲端服務是由許多個組織來一起共享，以支援特定的服務，像是目前由相關單位所推動的醫療雲、教育雲等，以共同的訴求和具有相同使命的目的為號召，提供給特定對象使用。以上描述屬於哪一種雲端服務的部署模式？ (A) 公有雲 (Public) (B) 私有雲 (Private) (C) 混合雲 (Hybrid) (D) 社群雲 (Community)
C	45. 下列何者「不」是雲端服務 (Cloud Service) 的關鍵特徵？ (A) 隨需自助服務 (On-demand Self-service) (B) 多人共享資源池 (Resource Pooling) (C) 情境最佳化 (Scenario Optimization) (D) 快速重新部署靈活性 (Rapid Elasticity)
C	46. 關於行動裝置的安全防護，下列敘述何者正確？ (A) iOS 手機才會中毒，Android 手機不會中毒 (B) iOS 手機不會中毒，Android 手機才會中毒 (C) iOS 和 Android 手機都可能中毒 (D) iOS 和 Android 手機都不會中毒
B	47. 疫情期間，居家上班成為重要防疫處置，某 IC 設計公司，擔心員工在家使用 Smartphone 或 Laptop 收發公司郵件，恐有附件機密資料外洩疑慮，下列哪一個選項，「最不具備」資料保密措施？ (A) 手機透過 VPN 登入公司網路，在虛擬化桌面環境 (VDI) 中收取電子郵件，無法讓附件儲存在個人手機中 (B) 讓公司員工直接遠端 (RDP) 登入到公司配發個人電腦，收發電子郵件

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 12 頁，共 13 頁

	(C) 公司配發專用手機，手機充電孔已不具備資料傳輸能力，NFC 也被禁用，必須透過 VPN 才能連線公司郵件伺服器 (D) 公司配發專用 Laptop，且安裝資料外洩防護（DLP）進行管控外接儲存裝置、網路傳輸活動，必須透過 VPN 連上公司郵件伺服器
C	48. 關於行動裝置安全的方案，下列何者較「不」適當？ (A) 利用端點安全方案，監控公司每部存取網路行動裝置檔案與程式，透過持續掃描惡意行為，來及早識別威脅 (B) 透過 VPN 讓裝置到公司網路加密連線，確保安全傳輸資料，防止未經授權人員竊聽，讓員工安全地進行遠距工作 (C) 員工在公司電腦安裝隱匿通道（Tunnel）保護家裡到公司的連線，確保只有自己可以使用，來安全傳輸資料 (D) 提升電子郵件安全，透過檔案內容淨化與重組（CDR）進行郵件檔案清洗，阻絕勒索病毒或是惡意檔案，利用行動裝置擴散到公司網路
皆給分	49. 物聯網架構具有三個層次，包含感知層、網路層、應用層，下列哪一個選項的傳輸服務皆屬於網路層？ (A) 電信網路（如 3G、4G LTE、5G）、RFID、GPS (B) 電信網路（如 3G、4G LTE、5G）、Wi-Fi、電子羅盤（Electronic Compass） (C) Wi-Fi、RFID、GPS、Bluetooth (D) 電信網路（如 3G、4G LTE、5G）、Wi-Fi、RFID、Bluetooth
C	50. 請問在物聯網裡，若因為外來超強訊號的干擾而產生「蓋臺」的現象，造成裝置之間互聯時受影響，此為下列何種攻擊手法？

112 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目 2：I12 資訊安全技術概論

考試日期：112 年 6 月 3 日

第 13 頁，共 13 頁

	(A) 中間人攻擊 (Man-In-The-Middle Attack) (B) 資料隱碼攻擊 (SQL Injection Attack) (C) 阻斷服務攻擊 (Denial-of-Service Attack) (D) 隱藏欄位攻擊 (Hidden-Field-Tampering Attack)
--	--